

ISO 27001 Access Control Summary

(Aligned with ISO/IEC 27001:2022 – Annex A Controls)

Overview

This document provides a structured summary of ISO 27001 access control requirements relevant to enterprise systems handling sensitive or regulated data.

The focus areas include:

- Control objectives for access control
- Role-based access management
- Access review cadence
- Logging and monitoring requirements

This summary is intended for policy alignment, system design, and compliance simulation purposes.

1. Access Control Objectives

1.1 Business Requirement for Access Control

Access to information and information processing facilities shall be:

- Restricted to authorized users
- Aligned with business and security requirements
- Based on the principle of least privilege
- Reviewed periodically

Access control policies must define:

- Who can access what resources
- Under what conditions
- Through which authentication mechanisms
- With what level of monitoring

1.2 Principles of Access Control

Principle	Description
-----------	-------------

Least Privilege	Users receive only the minimum access necessary.
Need-to-Know	Access granted only if required for job role.
Segregation of Duties	Critical tasks divided to prevent fraud or abuse.
Role-Based Access Control (RBAC)	Access assigned based on defined roles.
Accountability	Every access must be traceable to an individual identity.

2. Access Management Controls

2.1 User Registration & De-Registration

Organizations shall implement formal procedures for:

- User onboarding approval
- Identity verification
- Access provisioning
- Timely removal of access upon termination or role change

Termination access removal must occur:

- Immediately upon employment end
- Within 24 hours for high-risk roles

2.2 Privileged Access Management

Privileged access shall be:

- Restricted to authorized personnel
- Approved by management
- Logged and monitored
- Reviewed more frequently than standard user access

Multi-factor authentication (MFA) is required for:

- Administrative accounts
- Remote access
- Access to sensitive data repositories

2.3 Access Review Cadence

Access rights shall be reviewed periodically to ensure continued necessity and appropriateness.

Access Type	Review Frequency
Standard user access	Quarterly
Privileged/admin access	Monthly
Third-party/vendor access	Before renewal or every 90 days
Dormant accounts	Automatic disable after 30–60 days

Review process must include:

- Verification by line managers
 - Confirmation by system/data owners
 - Documentation of review outcomes
 - Removal of unnecessary access
-

3. Authentication & Authorization Controls

3.1 Authentication Requirements

Systems shall implement:

- Strong password policies
- Multi-factor authentication (MFA)
- Secure session management
- Lockout mechanisms for repeated failed attempts

Passwords must:

- Meet minimum complexity standards
- Be hashed and salted
- Never be stored in plaintext

3.2 Authorization Enforcement

Authorization must:

- Be enforced at the application layer
- Be validated on every request
- Prevent horizontal and vertical privilege escalation

- Use centralized identity management where possible
-

4. Logging & Monitoring Requirements

4.1 Logging Objectives

Logging ensures:

- Traceability of user activity
- Detection of unauthorized access
- Investigation of incidents
- Evidence for audits

4.2 Mandatory Logging Events

Systems shall log:

- Successful and failed login attempts
- Privileged account usage
- Access to sensitive data
- Changes to permissions
- Configuration changes
- Account creation and deletion

4.3 Log Protection Requirements

Logs must be:

- Tamper-resistant
- Time-synchronized
- Stored securely
- Retained per retention policy
- Access-restricted

Access to logs must be limited to:

- Security teams
- Compliance officers
- Authorized auditors

4.4 Log Review Cadence

Log Type	Review Frequency
Authentication logs	Daily automated review

Privileged activity logs	Daily manual review
System configuration changes	Weekly
Security alerts	Real-time

Automated alerting mechanisms must exist for:

- Multiple failed login attempts
 - Privilege escalation attempts
 - Unauthorized access attempts
 - Anomalous behavior patterns
-

5. Incident Support & Audit Alignment

Access control mechanisms must support:

- Forensic investigation
- Root cause analysis
- Regulatory reporting
- Compliance audits

Access control logs shall integrate with:

- Security Information and Event Management (SIEM) systems
 - Incident response workflows
 - Audit reporting dashboards
-

6. Control Mapping Example

ISO 27001 Control Area	Enterprise Implementation
Access Control Policy	Information Security Policy
User Access Management	RBAC & IAM System
Privileged Access	PAM Solution + MFA
Logging & Monitoring	Centralized SIEM + Audit Logs

Access Review	Quarterly Certification Process
---------------	---------------------------------

Compliance Assurance

To maintain ISO 27001 alignment, organizations must:

- Maintain documented access control policies
- Perform periodic internal audits
- Track corrective actions
- Demonstrate evidence of review and enforcement

Disclaimer:

This document is a structured summary for educational and system-design purposes and does not replace official ISO/IEC 27001 documentation. For certification and legal compliance, refer to the official standard.